

Incident Summary Report

SOC Detection Home Lab | Active Directory Environment | mydfir.local

Incident ID	Date	Title	Severity	Status
INC-2026-001	June 8, 2026	Multi-Stage Intrusion: Brute Force, Persistence, Execution, Reconnaissance	HIGH	Resolved
Analyst	Environment	Affected Host	Attacker IP	Detection Source
Tahmid Abtahee	Lab / VirtualBox	target-PC.mydfir.local (192.168.10.100), ADDC01.mydfir.local (192.168.10.7)	192.168.10.250	Splunk + Sysmon

Executive Summary

A multi-stage simulated attack was detected against the mydfir.local Active Directory environment. An attacker originating from 192.168.10.250 (Kali Linux) executed an RDP credential brute force using Crowbar, generating 12 failed logon events before successfully authenticating. Post-exploitation activity was then simulated via Atomic Red Team, covering unauthorized account creation (T1136.001), PowerShell-based execution including a Mimikatz attempt (T1059.001), and local account discovery (T1087). All four techniques were detected in Splunk. The environment was confirmed clean following investigation. No persistent access, lateral movement, or data exfiltration occurred.

Attack Timeline

Time (UTC)	Technique	Activity Observed
~9:31 PM	T1110 - Brute Force	Crowbar initiated RDP brute force from 192.168.10.250 against target-PC (port 3389). 12 EventID 4625 failures detected in a sub-second window, confirming automated tool behavior. Successful authentication followed.
~3:43 AM	T1136.001 - Create Account	Atomic Red Team created local account NewLocalUser via PowerShell and added it to the local Administrators group. Account deleted after creation. EventID 4720 logged the creation independently and was not removed with the account.
~3:43 AM	T1059.001 - PowerShell Execution	Atomic Red Team attempted execution of Mimikatz and BloodHound via PowerShell. Windows Defender blocked Mimikatz. EventID 4688 captured the process creation attempt regardless of the block, producing 120 process creation events across the test window.
~3:54 AM	T1087 - Account Discovery	Local account enumeration executed via built-in Windows utilities invoked through PowerShell. Process creation events captured in Sysmon and Security logs confirmed the discovery activity.

Detection Evidence

- EventID 4625 (Failed Logon):** 12 failures from 192.168.10.250 clustered in a sub-second window. Queried via `index=endpoint EventCode=4625 | stats count by src_ip Account_Name host | where count > 10`. Temporal clustering confirmed automated tool, not user error.
- EventID 4720 (Account Created):** NewLocalUser creation logged and confirmed via `index=endpoint EventCode=4720`. Creation record persisted in Splunk after account deletion. `Subject_Account_Name` field identified the creating context.
- EventID 4688 (Process Creation):** 120 events returned across the test window via `index=endpoint EventCode=4688`. Mimikatz process creation event captured despite Windows Defender blocking execution, confirming SIEM-level detection is independent of EDR outcome.
- Sysmon Operational Log:** Parent-child process relationships confirmed T1087 account discovery via PowerShell invoking built-in enumeration utilities. Olaf Hartong configuration provided process hashes and command-line arguments not present in default Windows logging.

Containment, Eradication, and Recovery

- **Containment:** Attacker IP 192.168.10.250 confirmed as the designated lab Kali machine. No external access to the environment existed. Network isolation was inherent to the VirtualBox NAT configuration.
- **Account review:** NewLocalUser confirmed deleted by Atomic Red Team cleanup. No additional accounts were created outside the simulation. All domain accounts (MYDFIR\Saiba, MYDFIR\taho) reviewed and confirmed uncompromised.
- **Process review:** All suspicious processes identified via EventID 4688 were confirmed as Atomic Red Team test artifacts. No persistence mechanisms (scheduled tasks, registry run keys, services) were identified on target-PC or ADDC01.
- **Eradication:** No malware or attacker tooling remained on any host post-simulation. Atomic Red Team cleanup routines executed successfully and were verified against process creation logs.
- **Recovery:** Environment verified clean. All VMs returned to normal operation. No domain accounts required password resets. No Group Policy changes were required.
- **Current status:** Incident closed. No ongoing threat activity detected. Detection rules validated and documented for future use.

MITRE ATT&CK Coverage

ID	Technique	Detection Method	Data Source	Result
T1110	Brute Force (RDP)	EventID 4625, count threshold SPL	WinEventLog:Security	Detected
T1136.001	Create Local Account	EventID 4720, Subject_Account_Name field	WinEventLog:Security	Detected
T1059.001	PowerShell Execution	EventID 4688, parent process filter	Sysmon + Security Log	Detected (blocked by Defender)
T1087	Account Discovery	Sysmon process creation, cmd chain	Sysmon Operational	Detected

Lessons Learned

- **No account lockout policy was configured:** 12 failed RDP attempts went unthrottled. In a production environment this would allow unlimited credential guessing. Account lockout after 5 failures and MFA on RDP would have stopped this attack at the initial access phase.
- **Blocked attacks still produce forensic evidence:** Windows Defender prevented Mimikatz from executing but EventID 4688 captured the attempt. Disabling or tampering with EDR does not eliminate SIEM-level visibility when process creation logging is configured correctly.
- **Deleted accounts leave permanent creation records:** NewLocalUser was removed immediately after creation but EventID 4720 persisted in Splunk. Attackers who create and delete backdoor accounts cannot erase the creation event from the SIEM.
- **SPL query precision determines detection accuracy:** A free-text search for NewLocalUser returned zero results. Querying by EventCode 4720 returned the correct detections. Detection logic must be anchored to specific event codes and field names, not keyword searches.
- **Sysmon is non-negotiable for process-level visibility:** Default Windows logging captured EventID 4688 but without parent process context, command-line arguments, or process hashes. The Olaf Hartong Sysmon configuration provided all three, reducing triage time significantly.